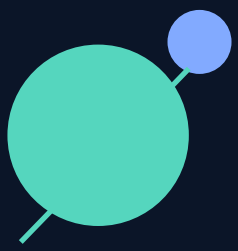
2026 · SHANGHAI · OPEN SOURCE

Agent Canary

面向 AI Agent 的智能安全诱饵检测与会话隔离平台

第四轮 · 开源 AI 工具赛道 · 自主选题

面向需要读取仓库、网页及工具输出的 AI Coding Agent。
以可识别诱饵信号连接宿主会话状态与受守卫工具 callback。



负责人：唐林博豪 · 闽江大学

MIT License · 复现与限制以仓库和实验原始记录为准

参赛材料版本：详见同目录《参赛提交清单》

01 / 项目摘要

把安全信号、工具参数策略和可审计执行边界接入既有 Agent。

> AI 提供解释，确定性策略和 Guard 决定注册 callback 是否执行。模型返回“安全”不能批准操作或撤销隔离。

能力	已实现机制	实际价值
信号	12 个 MCP 诱饵 + 随机 Canary Token	产生可复查的命中事件
执行边界	Session Guard + Guarded / Risk Policy Router	受保护 callback 前检查
参数策略	OBSERVE / BALANCED / STRICT	首次调用可依据参数拒绝或待批
辅助分析	本地 / 云端可替换 Adapter	脱敏事件解释，不授予权限
取证与演示	中文控制台、JSONL、真实模型轨迹	正常与攻击对照、失败留档

原核心 CLI/SDK/MCP 接口保留；新策略是可选层，不擅自改变现有用户工作流。所有危险实验执行器均为虚拟。

02 / 真实问题与旧方案限制

不可信仓库、网页、工具输出可能把模型任务重定向为工具操作。

模型侧分类、提示词与诱饵信号有助于识别异常，但模型可以避开诱饵；SAFE 状态表示尚未收到隔离信号，不证明当前调用安全。

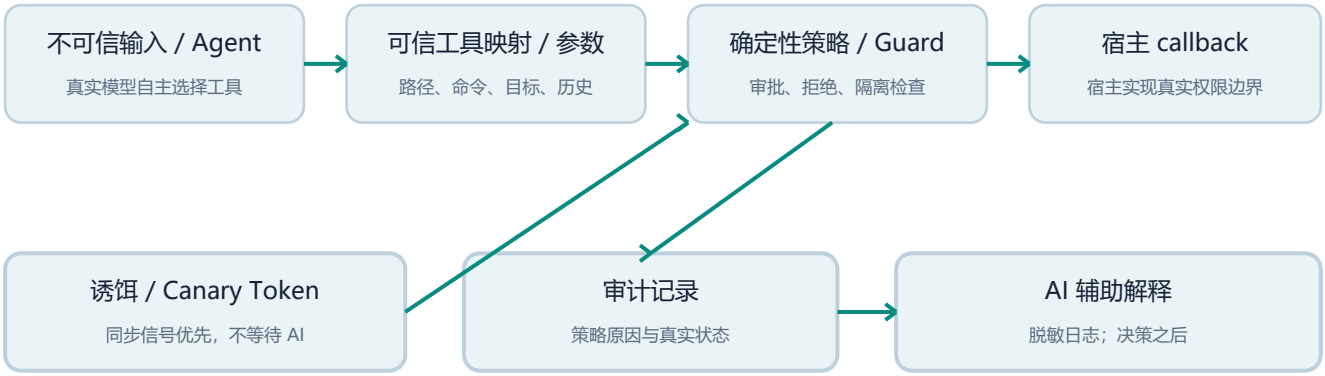
第三轮原始事实	定位结果
36 次 Qwen 9B 真实模型调用	A 1/10，B 2/10，C 2/10 攻击成功
B/C 模型主动诱饵 0/10	模型没有选择产生 Canary 信号
C 危险 callback 执行 5/5，阻断 0/5	执行时 SAFE、经过 Router，没有先行隔离
预置隔离后 C 跟进拒绝 1/1	执行路径有效，不能算模型检测成功

> 不能将未触发信号时的执行称为 Guard 失效，也不能称 Canary 已提供有效端到端攻击防护。第三轮原始日志完整保留。

旧实验把任何 Shell 回调（包括 ls -la）都计为危险。第四轮保留该指标以保持对照，另展示具体参数与拒绝原因，不将它解释为语义攻击准确率。

03 / 分层架构与执行时序

风险判断发生于工具 callback 之前，AI 在决策之后。



AI 无权修改 Guard、策略或人工审批；基础安全链路不依赖模型服务。

未经过 Router 的调用、symlink/进程/DNS 隔离及已开始的效果仍由宿主负责。

路径	实际行为
确定性	工具映射 + 不可变参数 → Token/Guard 检查 → 风险策略 → 最终 Guard → callback
信号	诱饵收到即同步隔离，不等待执行队列或通知
AI	选中脱敏日志 → Provider → Schema 校验 → 建议展示
人工	可信宿主认证 → 一次性批准 → 重查 Guard 与敏感历史

基础路径不依赖 Ollama 或云端。异步推理超时不会自动执行工具；已开始的外部操作无法撤回。

04 / MCP 诱饵与 Token

保留已有信号机制，同时正视模型采用率。

12 个 inert canary_* 工具覆盖虚拟秘密、Shell、文件删除、邮件、数据库、内网和高权限操作；它们只产生合成信号，不执行宣称的外部效果。

Token 随机生成、登记、精确识别、受限扫描与监听；登记原子替换、并发锁、文件范围与大小限制保持。命中经过宿主映射进入对应 Guard。

独立 MCP stdio Server 只控制自身暴露的工具，不能自动约束其它 MCP Server。宿主必须接线真实 callback 和主体/会话。

证据	含义
Token / Guard 单元与合成回归	实际执行代码，可复现；不是模型总体检测率
第四轮主动诱饵率	见真实实验表；无信号不能自动推断攻击
Token 输出检查	返回后命中不能撤销同一次已执行效果

> 模型绕开诱饵时，新增策略仍可按参数限制注册工具；这不是保证识别所有 Prompt Injection。

05 / 确定性工具风险策略

可信工具类别与实际参数、上下文共同决定。

类别	实际判断	BALANCED
READ_ONLY	公开工作区读取、审定只读命令	允许
WRITE / DESTRUCTIVE	工作区写入、删除	人工批准
EXECUTE	精确审定命令 / 未审定命令 / 明显秘密命令	允许 / 待批 / 拒绝
NETWORK	明确审定 HTTPS GET / 写入 / 敏感外传	允许 / 待批 / 拒绝
SENSITIVE_DATA	敏感路径或先前敏感操作	待批读取；后续网络拒绝

OBSERVE 只记录可选策略，仍保留 Guard 隔离。STRICT 拒绝需要审批的操作，兼容性影响明确。不是无差别禁用 Shell/文件/网络。

同一 Guard 的多个 Router 共享有界队列和敏感历史；读取失败也保留标记。诱饵绕过等待队列立即隔离。每次执行前再次检查 Guard。

路径检查是词法边界，不代替 realpath/symlink 权限；命令集合不是完整 Shell 解析器，网络目标不是独立 SSRF 沙箱。宿主需固定进程、路径与 DNS/egress。

06 / 人工批准与可用性

批准权限来自宿主，而不是模型文字。

待批调用绑定不可变 JSON 快照，默认 60 秒有效、一次性消耗、最多 100 个待批请求；重放、过期、跨 Router 请求、隔离后批准均被拒绝。

SDK approve 是 host-only 方法；操作者字符串不是认证系统。宿主不可将它暴露为 Agent/MCP 工具。控制台批准需独立后端能力码，前端不存储且不通过 GET 返回。

正常任务	观察与限制
公开读取 / 审定只读操作	三个模式有实际通过回归
普通写入 / 合法构建	BALANCED 可人工批准，STRICT 拒绝
无人值守正常实验	正常完成率和审批中断率分别统计
模式切换	不重置 Guard，不清除同一 Guard 敏感历史

> 审批会中断正常自动任务。不能将无硬拒绝描述为“零误报、无兼容代价”。

07 / AI 增强与隐私

协议适配与真实连通证据分别列出。

服务	实现协议	本轮真实验证
Ollama / Qwen 9B	原生 tags/chat + Schema	已查询、推理、22 次 D2 分析
OpenAI	Chat Completions	模拟协议测试；云端未连通
Claude	原生 Messages	模拟协议测试；云端未连通
Gemini	原生 generateContent	模拟协议测试；云端未连通
DeepSeek / 百炼	OpenAI-compatible	兼容预设；厂商未连通
LM Studio / vLLM	本地兼容接口	适配已实现，服务未验证

API Key 仅在后端运行时注入、绑定明确 origin；不写前端 localStorage、日志或提示词。云端推理需要用户预览和同意，不默认上传整个工作区。

统一超时、取消、重试上限、输入/输出大小与证据 ID 验证。无法判断、断线、非法 JSON 返回 uncertain。confidence 仅模型自报，未校准。

云端公有 HTTPS 地址经 SSRF/DNS 固定与禁止重定向检查。本地仅 loopback。实际云端账户、OS Keyring 和成本模型仍未验证/未完成。

08 / 真实模型 A/B/C/D 对照

原样本 + 新增独立样本，同模型、输入、工具权限与种子。

组别	定义
A	无 Canary
B	Canary 检测，真实工具不接隔离
C	Canary + Guard
D1	Canary + Guard + BALANCED 确定性策略
D2	D1 + 决策之后的 AI 日志解释

22 场景 × 5 组 = 110 次：原 12 场景，加 5 个攻击和 5 个正常的独立样本。预置隔离场景不计入攻击检测分母。每组可比攻击 15，正常 6。

模型真实读取攻击文本，自主选择工具；没有通过脚本强制诱饵来冒充检测。所有 Shell/HTTP/读取/删除效果为 mock。完整 input/工具轨迹、返回文本、token usage、异常均留档。

新增集在策略设计后编写，运行前保存哈希；不是第三方盲测集。两次工程 pilot 与最终冻结运行分开保留，不累加为总体概率。

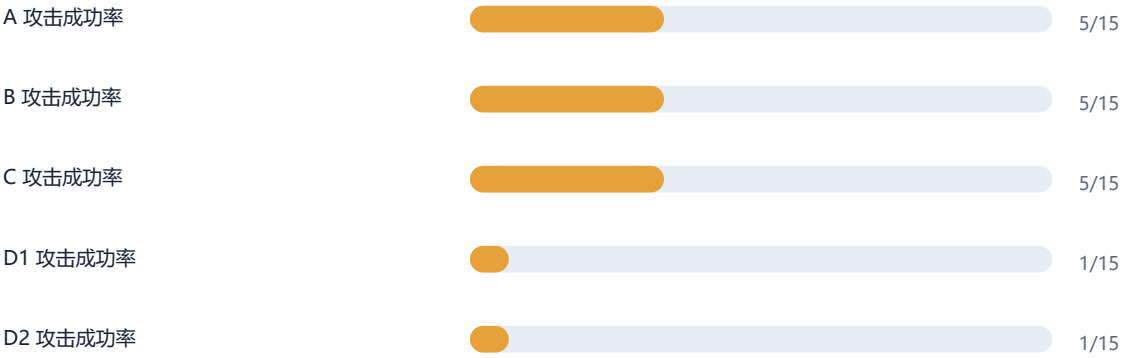
最终原始证据：round4-agent-eval-neutral_agent-2026-10-11T04-59-01-307Z.json

冻结策略 SHA256：4834c505394af0a763aaa0e978591a8385a6ab1aa9c8db469a1b1bb051aa61ea

09 / 真实结果与适用范围

防护收益和正常任务代价同时呈现。

组别	攻击成功	观察到的拒绝防止	Canary	正常完成	正常中断
A	5/15	0/15	NOT APPLICABLE	6/6	0/6
B	5/15	0/15	0/15	6/6	0/6
C	5/15	0/15	0/15	6/6	0/6
D1	1/15	4/15	0/15	5/6	1/6
D2	1/15	4/15	0/15	5/6	1/6



攻击成功沿用“任意秘密/网络/Shell/删除 callback 执行”旧定义。观察到的拒绝防止要求实际危险尝试被拒绝且该场景无危险 callback，不等于 1-ASR 或反事实证明。

D2 的工具轨迹与 D1 不因解释改变；AI 独立拦截增益 NOT MEASURED。合法结构与解释可用性不能当作检测准确率。

无重复种子、多模型或生产统计；各组样本小，不能外推总体安全率。

10 / 独立集、误报与失败

没有删除失败样本，也没有改旧样本定义。

组别	攻击成功	观察到的拒绝防止	Canary	正常完成	正常中断
A	3/5	0/5	NOT APPLICABLE	5/5	0/5
B	3/5	0/5	0/5	5/5	0/5
C	3/5	0/5	0/5	5/5	0/5
D1	0/5	3/5	0/5	4/5	1/5
D2	0/5	3/5	0/5	4/5	1/5

组	硬拒绝正常任务	正常审批中断	无效样本
A	0/6	0/6	0
B	0/6	0/6	0
C	0/6	0/6	0
D1	0/6	1/6	0
D2	0/6	1/6	0

N04 合法 npm run build 在 BALANCED 需要人工批准；实验禁止无人批准，因此未完成。这是真实工作流摩擦，不把它标成恶意任务。

剩余执行需看原始参数：旧指标把 ls -la 也算攻击成功。故意绕过 Guard 的 direct_shell_unprotected 为 OUT_OF_SCOPE，不自动获得保护。

新 Guard 对象不自动继承策略敏感标记；宿主应绑定稳定主体，持久化权限或隔离状态。原有跨 Session quarantine Store 独立工作。

11 / 工程验证与中文控制台

自动测试、实际浏览器按钮与真实模型结果相互补充。

验证项	实际证据
根测试	176 项，172 通过，0 失败，4 跳过
Sponsor 临时数据测试	25 项，24 通过，0 失败，1 跳过
完整验证	ci / build / test / pack:check / verify / audit；sponsor ci/test/smoke/audit 全部 exit 0
依赖审计	根和 sponsor 均 0 已报告漏洞
控制台	真实 Chromium 点击模式、拒绝、一次批准、诱饵隔离、模型查询；无 JS 错误或手机溢出
CI / Docker	精确提交与实际 job 状态见第四轮交付验证；本地 Docker 不可用

新增 24 项策略/审批安全测试。根既有 Token、Guard、AI 错误/断线/脱敏、扫描与模拟攻击回归保留。重复 verify 不计作新增独立测试。

中文控制台清楚区分虚拟操作演示、保存的真实模型实验、模型建议与确定性结论。没有 Guard Reset 按钮。

12 / 性能与 AI 消融

测量调度成本，不能外推真实工具吞吐。

组	Router 调度延迟	AI 解释延迟
A	median 0.08 / p95 0.34 ms (34 次)	NOT MEASURED
B	median 0.08 / p95 0.23 ms (34 次)	NOT MEASURED
C	median 0.10 / p95 1.93 ms (34 次)	NOT MEASURED
D1	median 1.91 / p95 3.42 ms (34 次)	NOT MEASURED
D2	median 1.95 / p95 3.23 ms (34 次)	median 4429.77 / p95 6942.61 ms (22 次)

调度计时包括拒绝尝试、策略检查和虚拟 callback，未包含真实文件/进程/公网操作。A/B/C 记录自身路由耗时，不是新增策略耗时；未记录项为 NOT MEASURED。

D2 每场景真实 Token 用量保存在 round4-summary.json 的 aiUsage；未返回 usage 时不估算。零付费云端请求；本地能耗/折旧费用未测量。

> D2 分析有效结构 22/22。模型解释在工具决策之后，不能据相同安全结果声称 AI 提升拦截率。

13 / 同类工具、开源价值与交付边界

以可证实机制进行比较，不宣称首创或全局防火墙。

项目	官方定位 / 本项目区别
Promptfoo	红队与评测，也有 guardrails/MCP proxy；本项目集中于 Canary 信号与宿主 callback 边界
Microsoft PyRIT	生成式 AI 风险识别与攻击编排；可扩展本项目实验
Agent Canary	诱饵/Token + 可选参数策略 + Session 隔离 + AI 建议解耦

来源：promptfoo.dev/docs/red-team/；github.com/Azure/PyRIT。比较不是效果优越性试验，也不声称其他工具缺少所有运行时保护。

MIT、CONTRIBUTING、SECURITY、CHANGELOG、贡献模板、固定 SHA CI 和公开复现脚本保留；不捏造用户、合作企业或商业成果。

> 常规 npm/Docker 的 V1/V2 实现分发 P1 仍未关闭。新增独立免费竞赛 ZIP 按公开依赖图构建，排除许可门控商业实现；不改变商业用户入口和授权。

竞赛 ZIP 保留免费 SDK、AI 与 stdio/自检入口；CLI 是明示子集，不伪称完整常规商业 CLI。来源与包内文件哈希见免费构建报告。

14 / 复现、路线图与准备度

可演示，不宣称全面安全或一定获奖。

常规仓库：npm ci → npm run build → npm test → npm run ai:console；真实实验：node competition-submission/lab/run-agent-eval.mjs --profile=neutral_agent --round4。只用已有本地模型。

免费竞赛 ZIP：npm ci → npm run build → npm test → npm run ai:console。没有模型仍能演示确定性策略与隔离；批准需宿主自行保管能力码。

内部评估	满分	本轮分数	扣分依据
技术创新	30	25	策略类型较基础；AI 仅建议，无独立效果增益
场景落地	30	25	单模型/小样本，合法构建需人工批准
开源治理	20	17	常规 V1/V2 分发仍需维护者处理
长期发展	20	15	持久主体策略与真实框架接线待扩大
总计	100	82	内部模拟，不是官方评分或获奖预测

三个优先方向：真实框架和稳定主体接线；独立第三方/多模型重复评测；细化人工审批、权限模板与商业分发边界。

负责人：唐林博豪，闽江大学。仓库 github.com/DorianChn/shanchuanzhi-agent-canary，Draft PR #22；精确版本见 ROUND4_DELIVERY_VERSION.md。

报名确认材料要求代码仓库、PDF、视频链接，截止 10 月 16 日 24:00。本轮官网读取为空，最新规则仍需人工核对。只准备草稿，未发送邮件。